

Vulnerability Assessment Report

1st March 2026

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 2025 to August 2025. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

The database server plays a crucial role in this business. It stores all customer data and allows employees to access that data upon request. The information stored on this server contains PII and SPII, and it is a public facing server. If a threat exposes any of this information while at rest or in transit, it could have severe consequences to both the business and customers. If the server becomes disabled by say a DoS attack, all business operations will come to a complete halt. It may take some time to correct if an attack happens which means the business will only continue after remediation, causing loss of revenue and productivity.

-

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
Hacker	Obtain sensitive information via exfiltration.	3	3	9
Employee	Alter/Delete critical information	3	3	9
Advanced Persistent Threat (APT)	Perform reconnaissance and surveillance of the organization.	3	3	9

Approach

Risks considered the data storage and management methods of the business. The likelihood of a threat occurrence and the impact of these potential events were weighed against the risks to day-to-day operational needs.

The above threat sources are highly likely to happen. This is a public facing server which leaves it vulnerable. If a threat were to exploit the server, PII and SPII could be exposed resulting in damage to property and possible fines from breaching compliance laws such as PCI-DSS. Internal access control policies such as MFA and least privilege must be implemented to keep all users authenticated and authorized.

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges. Encryption of data in motion using TLS instead of SSL. IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database.